VAPT TECHNICAL REPORT

TriosCyber & Ernith Internship Program — Day 30 Final Assessment

STUDENT / TESTER NAME: AZEEZ UMAR OPEYEMI

PROGRAM: UNDERGRADUATE CYBERSECURITY SCIENCE, LAUTECH

TARGET APPLICATION: DAMN VULNERABLE WEB APPLICATION (DVWA)

TARGET ENVIRONMENT: TRIOSCYBER & ERNITH INTERNSHIP PRACTICE LAB

DATE: SEPTEMBER 30, 2026

DOCUMENT VERSION: 1.0 (FINAL DELIVERABLE - DAY 30)

TARGET APPLICATION

Damn Vulnerable Web App (DVWA)

TARGET HOST IP

192.168.145.134

ASSESSMENT SCOPE

/dvwa/ (Security Level: Low)

DATE & VERSION

September 30, 2026 | v1.0 Final

1. EXECUTIVE SUMMARY

This technical document serves as the final deliverable for Day 30 of the VAPT Internship with TriosCyber (in partnership with Ernith). A scoped Vulnerability Assessment and Penetration Test was conducted against the Damn Vulnerable Web Application (DVWA) instance hosted on an authorized lab environment. The engagement identified multiple high-risk vulnerability vectors, including Remote Code Execution via OS Command Injection and client-side session hijacking via Reflected Cross-Site Scripting (XSS).

2. METHODOLOGY & LIFECYCLE

The assessment followed a structured, multi-phase testing workflow combining automated scanning with hands-on HTTP request manipulation:

1. Reconnaissance

Nmap port and service detection scans targeting ports 80 and 443.

2. Endpoint Discovery

FFUF directory fuzzing using active cookies to discover sub-paths.

3. Automated Scan

Nikto web vulnerability scanning to audit headers and configs.

4. Manual Testing

Burp Suite Repeater parameter manipulation and payload validation.

3. CONSOLIDATED SUMMARY MATRIX

4. DETAILED VULNERABILITY FINDINGS

Finding 1: OS Command Injection (Remote Code Execution)

HIGH SEVERITY

Vulnerable Endpoint: POST /dvwa/vulnerabilities/exec/

Vulnerable Parameter: ip

Technical Evidence: Appended shell operators in Burp Repeater to execute secondary system commands:

```
POST /dvwa/vulnerabilities/exec/ HTTP/1.1
Host: 192.168.145.134
Content-Type: application/x-www-form-urlencoded
Cookie: security=low; PHPSESSID=c8q05ruidd0b6otc507c15co0

ip=172.0.0.1%3B+whoami%3B+uname+-a&Submit=Submit
```

Impact: Full server takeover. Allows unauthenticated or low-privileged users to execute arbitrary system commands under the web server user context (`www-data`).

Remediation: Replace raw shell wrappers with native API calls or enforce strict input allowlist filtering using `filter_var($ip, FILTER_VALIDATE_IP)`.

Finding 2: Reflected Cross-Site Scripting (XSS)

MEDIUM SEVERITY

Vulnerable Endpoint: GET /dvwa/vulnerabilities/xss_r/

Vulnerable Parameter: name

Technical Evidence: Submitted unescaped script tags reflecting directly into the DOM:

```
GET /dvwa/vulnerabilities/xss_r/?name=%3Cscript%3Ealert%281%29%3C%2Fscript%3E HTTP/1.1
Host: 192.168.145.134
Cookie: security=low; PHPSESSID=c8q05ruidd0b6otc507c15co0
```

Impact: Client-side session hijacking, DOM manipulation, and credential theft via malicious script execution.

Remediation: Enforce context-aware HTML entity encoding using `htmlspecialchars()` and implement a strong Content Security Policy (CSP).

5. ACTIONABLE REMEDIATION ROADMAP

- **Immediate Priority (0–24 Hours):** Remediate OS Command Injection on `/vulnerabilities/exec/` by enforcing strict IP regex validation and eliminating shell wrappers.
- **High Priority (1–3 Days):** Apply HTML entity encoding across all user input reflection points in `/vulnerabilities/xss_r/` to prevent client-side script execution.
- **Medium Priority (1 Week):** Disable HTTP TRACE method globally, suppress Apache/PHP version banners, and deploy modern security headers (CSP, X-Frame-Options).